

BEFORE Placeholder

AFTER

Connectivity Control Baseline (VPN / Private Link / Inbound, Tiered)

Document classification: Internal

Baseline owner: Security Engineering/Architecture

Version: 0.1

Effective date: _____

Review cadence: Annually

1. Purpose

Define minimum security controls for third-party network connectivity (VPN, private link, and any inbound connectivity) to ensure segmentation, least-privilege routing, monitoring, and controlled change management.

2. Scope

Applies where a supplier requires:

- site-to-site VPN or private link connectivity
- routing between supplier and organisational networks
- inbound access into organisational environments (strongly restricted)
- agent/collector traffic that effectively creates persistent connectivity (where applicable)

3. Control statements (tiered)

3.1 Tier Critical (Tier 1) — MUST controls

Critical connectivity implementations MUST:

1. Use **least-privilege routing**:
 - deny-by-default; allow only required ports/protocols/hosts/subnets
2. Enforce **segmentation**:
 - terminate connectivity in a controlled zone (integration/DMZ segment)
 - prohibit flat routing into internal networks
3. Restrict **inbound connectivity**:
 - inbound is not permitted by default; if required, it must be explicitly approved and tightly constrained
4. Implement **change control**:
 - any route/port/rule changes are reviewed and approved prior to implementation
5. Provide **monitoring and logging**:
 - tunnel/link status (up/down), configuration changes
 - traffic telemetry (at minimum, firewall allow/deny summaries)
6. Define **ownership**:
 - IT/Platform Owner responsible for implementation and operations
 - Security Engineering/Architecture validates and approves
7. Support **offboarding**:
 - documented teardown steps to remove routes/rules and revoke keys

Critical connectivity SHOULD:

- implement redundancy for critical business services where availability requires it
- implement alerting for anomalous traffic, route expansion, and repeated failures
- use IDS/IPS or equivalent inspection where feasible

3.2 Tier Important (Tier 2) — MUST controls (exceptional use)

Important suppliers MUST meet the Critical connectivity controls if persistent connectivity is required. Default posture: if persistent connectivity is required, reassess whether the supplier should be Tier Critical.

3.3 Tier Low (Tier 3)

Low tier should avoid persistent connectivity. If required, re-triage and apply Tier Important/Critical requirements.

4. Baseline requirements by control area

4.1 Design and documentation

MUST:

- Document:
 - business justification for connectivity (why SaaS/API alternatives are insufficient)
 - endpoints, ports, protocols, environments (prod/non-prod)
 - data types transmitted
 - termination zone and segmentation boundaries
- Record approvals per governance.

4.2 Segmentation and routing

MUST:

- Terminate connections in a controlled zone (not directly into core networks).
- Use explicit routes and firewall rules; prohibit "any-any".
- Separate prod and non-prod connectivity where feasible.

SHOULD:

- Use separate security contexts/VRFs/contexts for supplier links where feasible to limit blast radius.

4.3 Inbound connectivity (special controls)

MUST:

- Avoid inbound connectivity by default.

- If inbound is required:
 - document necessity and scope
 - restrict to specific source IPs/hosts and ports
 - implement time-bound enablement where feasible
 - implement enhanced monitoring and approval

4.4 Cryptography and key management

MUST:

- Use strong encrypted tunnels with approved configurations.
- Store and handle tunnel keys/certificates securely.
- Define rotation owner and rotation trigger events (e.g., compromise, offboarding, admin changes).

SHOULD:

- Use certificate-based authentication where supported.

4.5 Monitoring, logging, and alerting

MUST:

- Log:
 - tunnel up/down events
 - configuration changes
 - firewall traffic telemetry (allow/deny metadata or summaries)
- Define:
 - monitoring owner
 - response expectations for outages and suspicious activity

SHOULD:

- Alert on:

- route changes / expanded subnets
- new ports opened
- inbound enablement
- unusual traffic volume or destinations
- repeated tunnel failures/flapping

4.6 Resilience (where required)

MUST (if the supplier supports a critical business service):

- Document whether connectivity is single-path or redundant.
- Document failover behaviour and maintenance windows.

SHOULD:

- Test failover at least annually (or per internal resilience requirements).

4.7 Change control

MUST:

- Route/port/rule changes require:
 - change request/ticket
 - security review/approval
 - post-change validation evidence
- Re-triage required for material expansions in scope (new systems, new data types, inbound access).

4.8 Offboarding and teardown

MUST:

- Decommission connectivity on termination:
 - remove tunnels/links
 - remove routes and firewall rules

- revoke/rotate any tunnel credentials/keys
- remove monitoring rules/runbook references
- Retain logs per retention policy.

5. Validation steps (how to prove it)

For each supplier connection, capture evidence and complete checks.

5.1 Design validation

- ☐ Justification documented
- ☐ Endpoint/port/protocol list documented
- ☐ Termination zone and segmentation documented

Evidence location:

5.2 Routing/firewall validation

- ☐ Deny-by-default confirmed
- ☐ Only explicit allowed ports/hosts/subnets configured
- ☐ No flat routing to internal networks

Evidence location:

5.3 Inbound validation (if applicable)

- ☐ Inbound necessity documented
- ☐ Inbound scope tightly constrained (IPs/hosts/ports)
- ☐ Explicit approval recorded
- ☐ Enhanced monitoring enabled

Evidence location:

5.4 Crypto/key management validation

- ☐ Tunnel encryption and authentication configured to standard
- ☐ Key/cert storage method documented
- ☐ Rotation owner and triggers documented

Evidence location:

5.5 Monitoring/logging validation

- ☐ Tunnel up/down logged
- ☐ Configuration changes logged
- ☐ Firewall telemetry available and retained
- ☐ Alerts configured for route/port changes (recommended)

Evidence location:

5.6 Resilience validation (if required)

- ☐ Redundancy model documented
- ☐ Failover test plan defined (and last test evidence if available)

Evidence location:

6. Exceptions

Any deviation from Tier Critical connectivity MUST controls requires:

- a policy exception with compensating controls and expiry date, and
- governance escalation where inbound connectivity, broad routing, or insufficient monitoring is involved.

7. Sign-off (per connection)

Supplier: _____ Service: _____ Tier: [] Critical []
Important [] Low

Security Engineering/Architecture (role title): _____ Date: _____ IT/Platform Owner
(role title): _____ Date: _____ Business Service Owner (role title):
_____ Date: _____